

COMPLETE STANDALONE TRANSCRIPTION

AWS Domain 2 - Security & Compliance

6 source pages • typed from the uploaded handwritten source • no external additions

Source-faithful edition. This document rewrites the uploaded handwritten notes into clean typed text. It preserves the concepts, examples, responsibility assignments, figures, service names, and practical notes **as written in the source**. No external material is added, and the notes are not externally verified or updated.

Source Page 1 - Shared Responsibility Model

Shared Responsibility Model

- A model that outlines **your responsibilities vs. AWS responsibilities** when it comes to **security and compliance**.

AWS responsibility - Security of the cloud

AWS is responsible for protecting and securing the underlying cloud infrastructure, including:

- Protecting and securing infrastructure.
- Controlling physical access to data centers (DCs).
- Network components.
- Software / managed-service infrastructure, with examples written in the notes such as **RDS, S3, ECS / Lambda-related infrastructure**, including underlying OS/host responsibilities.
- Managing the physical infrastructure architecture.
- Physically destroying storage media when required.

Customer responsibility - Security in the cloud

You are responsible for how services are implemented and for managing your application and data, including:

- Application data.
- Encryption of data.
- Securing your account.
- Securing API calls.
- Rotating credentials.
- Restricting Internet access.
- Patching the guest OS.
- Application security using identity and access management.
- Network traffic protection, including **Security Group / firewall configuration**.
- Installed software and application code.
- Scanning for vulnerabilities and patching vulnerabilities in your code / installed software.

Quick quiz - Who is responsible?

1. **Firewall configuration** → You / Customer.
 2. **Data-center security / physical building** → AWS.
 3. **Encryption of EBS volumes** → You / Customer.
 4. **Language versions of Lambda** → AWS.
 5. **Taking RDS database backups** → You / Customer.
 6. **Updating firmware on EC2** → AWS.
 7. **Ensuring data is encrypted at rest** → You / Customer.
 8. **Managing network infrastructure architecture** → AWS (as written in the source note).
 9. **Patching guest OS** → You / Customer.
 10. **Physically destroying storage media** → AWS.
-

Source Page 2 - Shared Security Responsibilities, EC2, Lambda, Trust & Safety

Shared security responsibilities

The notes list shared areas such as:

1. **Patch management.**
2. **Configuration management.**
3. **Awareness & training.**

Training example:

- **AWS trains its employees.**
- **You train employees in your organization.**

EC2 Shared Responsibility Model

You / Customer:

- Install the application.
- Patch the **guest OS**.
- Configure security controls.

AWS:

- Provides the **EC2 service**.
- Patches the **host OS**.
- Secures the **physical server**.

Lambda Shared Responsibility Model

You / Customer:

- Security of your code.
- Storage / handling of sensitive data.
- IAM permissions.

AWS:

- Provides the Lambda service.
- Upgrades the Lambda language/runtime.
- Provides Lambda endpoints.
- Manages the OS and underlying infrastructure dependencies.
- Manages underlying software dependencies, as shown in the source diagram.

AWS Trust & Safety Team

Used when you notice **abuse of AWS resources**.

Ways to contact:

1. Use the **Report AWS Abuse Form**.
 2. Contact via email: **abuse@amazonaws.com**.
-

Source Page 3 - WAF and AWS Shield

Security services - software-based security tools

1. AWS WAF - Web Application Firewall

- Helps protect a web application from common web attacks.
- Examples in the notes:
 - **SQL injection.**
 - **Cross-site scripting (XSS).**
- XSS explanation in the notes: an attacker targets the user with malicious scripts that execute in the browser and can expose/share private information.

Places where WAF can be deployed (as written)

1. Directly on / in front of **EC2**.
2. On **CloudFront**.
3. On an **Application Load Balancer (ALB)**.

2. AWS Shield - DDoS Protection Service

- A DDoS protection service.

Shield Standard

- **Free.**
- Provides free protection against common / frequently occurring attacks.

Shield Advanced

- **Paid.**
- Enhanced protection.
- Real-time protection / notification is noted.
- Access to AWS experts for a fee.
- The notes emphasize **24/7 access to experts.**

Services listed for Shield Advanced protection

1. **CloudFront** (with WAF mentioned alongside it in the notes).
2. **Elastic Load Balancer / Application Load Balancer.**
3. **Route 53.**
4. **Global Accelerator.**

Shield - real-world note

- Shield Advanced can provide notification of a **DDoS attack via CloudWatch metrics**.
 - You have **24/7 access to experts during the attack**.
 - Real-time notification is emphasized.
-

Source Page 4 - Macie, AWS Config, GuardDuty, Inspector

3. Amazon Macie

- Helps **discover and protect sensitive data**.
- Uses **machine learning behind the scenes**.
- Evaluates the **S3 environment** and uncovers **Personally Identifiable Information (PII)**.

Macie - real-world examples

Discover sensitive information on S3 such as:

- Passport number.
- Social Security number.
- Credit-card number.

4. AWS Config

- **Assess, audit, and evaluate configuration** of many AWS services.
- Tracks configuration changes over time.
- Delivers configuration history to **S3**.
- Notifications can be sent via **SNS** for every configuration change.

Config - real-world note

Record configuration changes related to EC2; the notes mention that you can view changes such as:

- Network configuration.
- Software configuration.
- OS configuration changes.

5. Amazon GuardDuty

- Uses **machine learning** to detect unauthorized behavior and threats.
- The notes say it has built-in detection for / around:
 - **EC2**.
 - **S3**.
 - **IAM**.
- Reviews / analyzes:
 - **CloudTrail** activity.
 - **VPC Flow Logs**.
 - **DNS logs**.

GuardDuty - real-world note

- Detect **unusual API calls** in your account.
- It evaluates API requests in the account and looks for activity associated with common techniques used by attackers.

6. Amazon Inspector

- Uncovers and reports **vulnerabilities on EC2 instances**.
- The source notes describe an Inspector agent on the EC2 instance.
- Reports vulnerabilities found and checks items such as:
 - Internet access.
 - Remote login.
 - Vulnerable software versions.

Inspector - real-world note

- Identify **unintended network access to an EC2 instance** through a detailed report.
-

Source Page 5 - Cognito, AWS Artifact, KMS

Amazon Cognito

- Provides different ways for a user to **log in to your application**.
- Helps manage users that use your application.
- Provides building tools to help users **sign up or sign in**.

Cognito - real-world example

- Add a **social-media sign-in** to your web application.
- Example: sign in via **Facebook or Google**.

Cognito vs account/resource access - source note

- The notes distinguish application-user access from AWS-account/resource access.
- Cognito is written as controlling access to an **application that you build on an AWS account** and providing **authorization and authentication for mobile and web applications**.
- For direct AWS-account / AWS-resource access, the notes point toward **IAM**.

7. AWS Artifact

- Offers **on-demand access to security and compliance reports**.
- Described as a **central repository for security & compliance reports from third-party auditors**.
- Examples written:
 1. **Service Organization Control (SOC) report**.
 2. **Payment Card Industry (PCI) report**.

Artifact - real-world example

- Access AWS certifications / reports for **ISO compliance**.

Encryption - AWS KMS (Key Management Service)

- Allows you to **generate and store keys for encryption**.
- Described as the place where you **store and control keys**.
- AWS KMS manages AWS encryption keys.

Services noted as having encryption automatically enabled / supported in the notes

1. **CloudTrail logs.**
 2. **S3 Glacier.**
 3. **Storage Gateway.**
-

Source Page 6 - Secrets Manager, KMS, CloudHSM

AWS Secrets Manager

Allows you to manage and retrieve secrets such as:

- Passwords.
- Keys.
- Database credentials.
- API keys.
- Other secrets.

Capabilities written in the notes:

- Easily retrieve your secrets.
- Manage your secrets.
- Rotate your secrets.
- Encrypt secrets at rest using encryption keys.

Integrations written in the notes

- **RDS.**
- **Redshift.**
- **DocumentDB.**

Secrets Manager - real-world example

- Retrieve the **database credentials** needed by application code.

KMS - real-world example

- Create an **encrypted EBS volume**.
- You can specify a **KMS customer master key** (wording as written in the source).

2. AWS CloudHSM

- Used to generate encryption keys using a **dedicated hardware module**.
- Allows you to **generate and manage your own keys**.
- The source emphasizes that **AWS does not even have access to your keys**.

CloudHSM - real-world example

- Meet compliance requirements for data security by using **dedicated hardware in the cloud**.

End of Domain 2 Notes

This document contains the clean written content of all **6 source pages** in the uploaded Domain 2 file, organized by source page and service.